

The CORE Framework | Process Mechanics

Reference copy. Source: <https://processmechanics.com/core/>

Retrieved 2026-06-05 · Process Mechanics PLLC / Van Lindberg · retained with permission for internal reference.

The CORE Framework for AI System Analysis

The EU AI Act (and similar legislation) describe two main types of controls: 1) controls on AI models, in particular models that are designated to pose a possibility of “systemic risk,” and 2) controls related to specific use cases that are considered to pose “unacceptable,” “high” or “minimal” risk. It also includes some policies regarding education, transparency, and reporting that apply to all AI systems.

From most companies’ perspective, however, most of what the EU AI Act regulates is out of scope. For example, most companies are unlikely to be using “subliminal, manipulative, or deceptive techniques” to distort people’s behavior, nor are they going to be trying to infer sensitive attributes like race or political opinions from biometric attributes. Most use cases and models fall into low risk categories (as defined by the EU AI Act).

But just because an AI system isn’t an EU AI Act “high risk” system doesn’t mean that governance is unneeded. A regulatory-only over-focus on just models and EU AI Act-influenced risk categories misses most of the issues that companies really care about:

- **Contractual Compliance & Third-Party Obligations.** Are all component licenses, API terms of service, and data processing agreements being followed throughout the system? This covers open source license obligations, commercial API usage restrictions, customer contract requirements, and vendor SLA compliance across the entire execution path.
- **Liability & Negligence Prevention.** Can your organization demonstrate reasonable care in system design and operation to defend against negligence claims? This requires documenting risk assessments, mitigation measures, testing protocols, human oversight implementation, and evidence of following industry standards of care.
- **Data Sovereignty & Confidentiality Controls.** Where does sensitive data (customer, employee, corporate confidential) flow and where is it stored? This encompasses cross-border data transfers, encryption requirements, access controls, and ensuring confidential information doesn't leak through model outputs or to unauthorized third parties.

- **Safety & Product Liability.** Could system failures or errors cause physical harm, property damage, or economic loss? To what extent does the use of AI systems affect the company's ability to meet contractual requirements and SLAs?
- **Transparency & Explainability Requirements.** Can the system provide required explanations to various stakeholders (regulators, customers, employees, auditors)? This varies by context—GDPR requires explanations for automated decisions, while SEC may require disclosure of AI use in material business processes.
- **Incident Response & Evidence Preservation.** When something goes wrong, can you reconstruct what happened and demonstrate proper response? This includes audit logging, version control, incident escalation procedures, and maintaining forensic capabilities for investigations or litigation.

The CORE Framework

Responsible AI (RAI) governance needs to be more than a general evaluation of the “risk” of a model. It needs to provide documentation of the organization's reasonableness and due diligence as demonstrated throughout the entire system. In order to provide this documentation, RAI teams need information about the entire AI system and how the models in the system interact with their environment. You can identify what is needed by using the acronym CORE: *Components, Operations, Resources, and Execution*.

The CORE framework represents AI systems as a system “blueprint” (technically a “directed graph”) where data flows through components. By documenting Components, Operations, Resources, and Execution paths, organizations can automatically evaluate policies, track compliance, and assess risks. The framework treats governance as a data flow problem rather than a documentation problem.

CORE works by translating developer/engineer-level knowledge (“What do we deploy?”) into a form suitable for policy-level analysis. IP protection becomes “what components access proprietary data?”, contractual compliance becomes “what third-party APIs are called?”, and liability prevention becomes “can we show what guardrails exist in the data flow?”

CORE not only works as a framework to guide information gathering and system analysis, but crucially, almost all of its steps can be automated, speeding up governance and simultaneously reducing risk. It is faster and more structured than questionnaire-based flows and more complete than model-centric approaches.

The CORE Framework Structure

Components are the nodes in the system blueprint. Each one is classified by type (e.g. LLM, database, API, guardrail, human-in-the-loop), and characterized by the operations and transformations it performs on data and the resources it accesses.

Operations are the actions components perform. Data operations transform or analyze data flowing through the system; resource operations read from or write to external systems. Each operation can add or remove tags that track properties of the data as it moves, which is what makes downstream policy evaluation possible.

Resources are the external assets the AI system does not control but must access, such as customer databases, third-party APIs, and filesystems. Resources sit outside the system boundary by definition. What CORE captures is the access pattern (read, write, delete) for each component-resource pair.

Execution refers to how data flows through the system. It is represented as the edges connecting components, with tags propagating along those edges to track properties like "PII" or "encrypted." Multiple execution paths may exist depending on routing logic, and each path is a separate object that policies can be evaluated against.

The PRO Policy Layer

The CORE framework provides a structured way to capture AI system architecture as a blueprint—a directed graph showing Components, Operations, Resources, and Execution paths. This blueprint answers the question "What does this system look like?" in a way that is meaningful to both developers and policy professionals. It translates technical knowledge into a form that governance professionals can analyze without reading code.

But documentation alone does not constitute governance. Governance requires analyzing the system's risk: Does this system comply with our policies? What are the risks associated with this system, and are they adequately controlled? Can we demonstrate due diligence to auditors and regulators?

These questions require a layer of logic that sits on top of the CORE blueprint to interpret it, enforce rules, and quantify risk. This is the role of the **PRO** extensions: Policies, a Risk register, and Outcome evaluations. Together, CORE+PRO transforms governance from passive documentation into active, automated compliance verification.

How CORE+PRO Enables Corporate AI Governance

PRO adds three capabilities to the CORE blueprint:

Policies translate organizational constraints into executable rules. Rather than relying on engineers to read policy documents and self-attest compliance, PRO policies run directly against the system blueprint. A policy like "Customer data cannot flow to third-party AI providers" becomes an automated check that either passes or fails, with specific evidence of which data flows caused any violations.

The Risk Register applies systematic failure analysis to identify and prioritize risks. Model Monster provides a **comprehensive taxonomy of risks cross-referenced to every major standard**, so coverage is complete by construction. Risky system designs are automatically flagged for human review where the analysis can identify them.

Outcomes are the generated artifacts that demonstrate governance occurred: compliance reports showing which policies passed and failed, risk summaries showing the system's overall risk profile, and violation logs identifying precisely where problems exist. These outcomes create the evidentiary chain that demonstrates reasonable care.

Risk Assessment with Defensible Methodology

When AI systems cause harm, organizations face questions about whether they exercised reasonable care. Vague assertions that "we assessed the risks" provide weak defense. The PRO system adapts governance for the probabilistic nature of AI: traditional software governance relies on binary checklists (Pass/Fail), which fail when applied to models that behave non-deterministically and guardrails that have non-zero failure rates.

PRO applies a Failure Modes and Effects Analysis (FMEA) methodology that scores risks Severity of failure, Occurrence (probability) and Detection (mitigation effectiveness). This allows the organization to quantify and prioritize risks like "Compounding Multi-Agent Failures" or "Indirect Injection" that cannot be completely eliminated, only managed to an acceptable threshold. Where appropriate, PRO analysis also incorporates Use Case documentation that captures business context - intended purpose, user population, deployment environment - that shapes risk assessment but isn't visible in the technical blueprint.

For governance teams, having a comprehensive risk register also makes it explicit which risks are being evaluated. It moves risk identification from an ad hoc process to a checklist-based process, making it easy to verify that nothing was missed.

What CORE+PRO Delivers

Together, CORE+PRO enables rapid, automated governance that both speeds up deployment and reduces risk.

For Developers and Product Teams: CORE+PRO gives software teams specific feedback about what needs to be done and what can be improved. Rather than saying

“we need to make sure this system is safe,” CORE+PRO identifies particular failure points and risky execution paths and describes exactly what gives rise to the risk.

For Legal and Compliance Teams: CORE makes complicated AI systems legible. PRO provides immediate evidence of reasonable care. When questions arise about whether the organization exercised due diligence, CORE+PRO evidence shows that policies were defined, systems were evaluated against those policies, risks were systematically assessed, and appropriate action was taken on findings. This evidentiary chain is far more defensible than attestation emails or meeting notes.

For Regulators: The EU AI Act's Article 9 (Risk Management) and Article 11 (Technical Documentation) require organizations to demonstrate systematic risk assessment and maintain technical documentation. CORE+PRO systems satisfy these requirements with structured data rather than narrative descriptions.

For Executive Leadership: CORE+PRO provides confidence that deployment decisions rest on rigorous analysis rather than verbal assurance. When a system is approved for deployment, leadership can see exactly what policies were checked, what risks were assessed, and what the findings were.